

1.0 Organization Profile

- FinSecure Pvt. Ltd.
- Industry: Financial Services
- Employees: 400
- Locations: Mumbai (HQ), Pune, Bengaluru
- IT Environment: Hybrid (On-Prem + Microsoft 365)
- IT Team: 8 members
- Security Team: No dedicated security team

1.1 Executive Summary

FinSecure Pvt. Ltd., a mid-sized financial services organization with approximately 400 employees across Mumbai, Pune, and Bengaluru, currently relies on a hybrid authentication architecture combining on-premise and cloud-based identity systems. The organization uses Active Directory for internal identity management and Microsoft 365 for cloud services, with VPN-based access for remote connectivity.

The existing authentication framework is primarily password-based, which exposes the organization to significant risks, as credential-based attacks contribute to a large percentage of modern breaches (over 20% as per industry reports, Verizon DBIR, 2023).

This assessment identifies key gaps in the current authentication system and highlights the need for implementing a robust Multi-Factor Authentication (MFA) framework. The goal is to enhance security, reduce the risk of unauthorized access, and ensure compliance with industry standards.

1.2 Current Authentication Overview

FinSecure currently operates a **hybrid authentication environment** consisting of:

- **On-Premise Systems:**
 - Windows Active Directory (AD) for user authentication
 - Internal applications for HR and loan processing
- **Cloud Systems:**
 - Microsoft 365 (Exchange, Teams, SharePoint)
 - Web-based client portal
- **Access Mechanisms:**
 - Username + password authentication
 - VPN access for remote employees
 - SSO (partially implemented for cloud services)

Table 1 provides a complete inventory of enterprise systems assessed, their current authentication methods, and associated risk levels.

1.2.1 Table 1: Enterprise System Inventory - FinSecure Pvt. Ltd. (Pre-MFA Assessment)

#	System	Type	Location	Users	Auth Method	MFA Enabled	Risk Level
1	Windows Active Directory	Identity / Directory	On-premise (Mumbai HQ)	All 400	Username + password	No	Critical
2	Microsoft 365 (Exchange, Teams, SharePoint)	Cloud productivity	Microsoft cloud	All 400	Username + password	No	High
3	VPN (Remote Access Gateway)	Network access	On-premise	~80 remote users	Username + password	No	Critical
4	HR Application	Internal web app	On-premise	HR team (~25)	Username + password	No	Medium
5	Loan Processing System	Internal web app	On-premise	Finance team (~40)	Username + password	No	High
6	Client Portal	External web app	Cloud-hosted	Customers + staff	Username + password	No	High
7	Admin / IT Accounts	Privileged access	On-premise + cloud	IT team (8)	Username + password (shared in some cases)	No	Critical

8	Email (Outlook / Exchange)	Communication	Microsoft cloud	All 400	Username + password	No	High
9	Azure AD / Entra ID	Cloud identity	Microsoft cloud	All 400	Synced from AD	No	Critical
10	RDP (Remote Desktop)	Remote access	On-premise servers	IT team (8)	Username + password	No	High

1.2.2 Key findings from this inventory:

- Zero systems have MFA enabled
- Three systems are classified Critical — AD, VPN, and admin accounts — all without any second factor
- The client portal is internet-facing with password-only authentication, making it the highest external exposure point
- Shared credentials on admin accounts means no individual audit trail exists

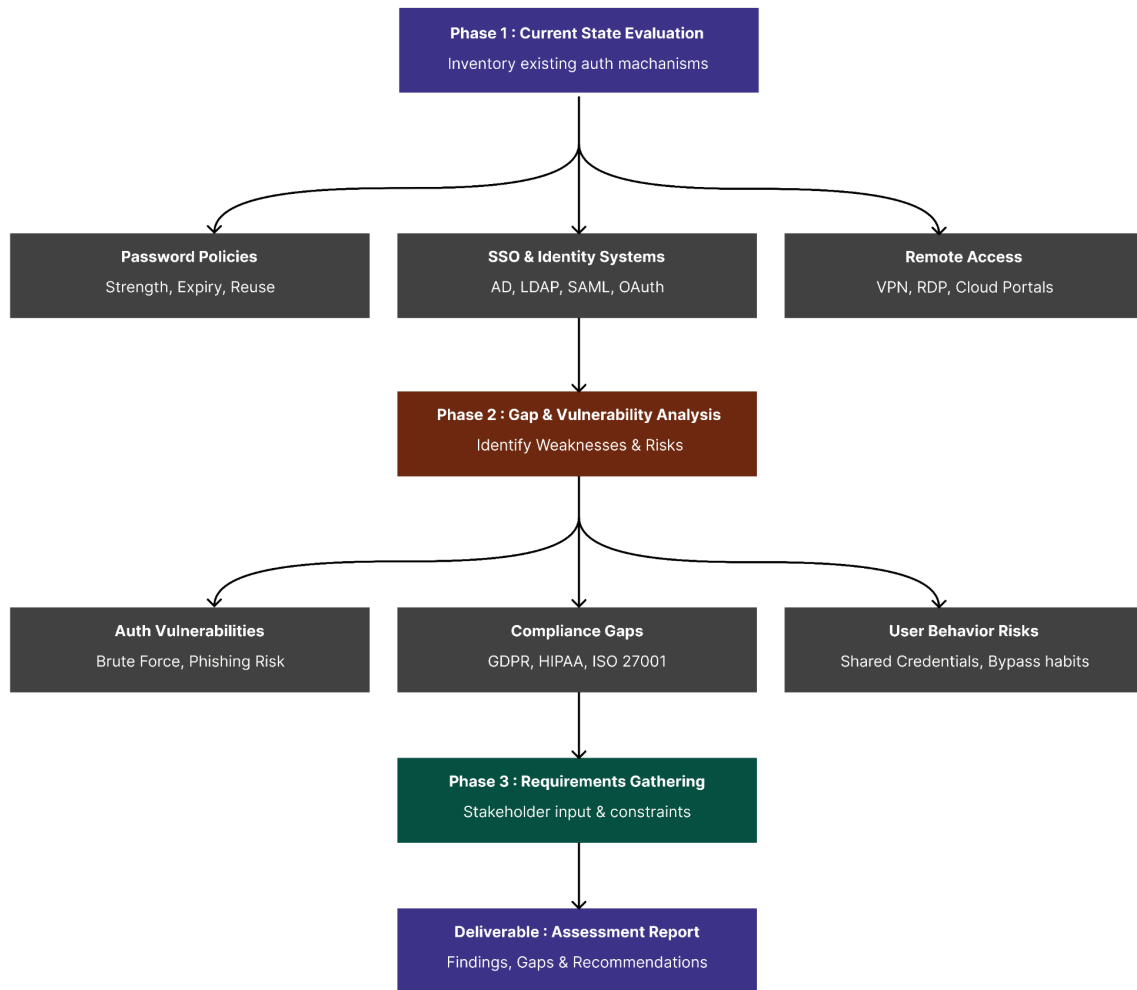


Figure 1: Current Authentication Assessment Framework at FinSecure Pvt. Ltd.

The above framework illustrates the current authentication landscape at FinSecure Pvt. Ltd., highlighting the interaction between users, authentication systems, and access mechanisms across on-premise and cloud environments. It provides a structured view for identifying existing vulnerabilities and areas requiring enhanced security controls.

1.2.3 Key Observations:

- Authentication is largely **single-factor (password-based)**
- Limited or no enforcement of MFA across critical systems
- Remote access (VPN) depends heavily on password security

1.3 Identified Gaps & Vulnerabilities

Given FinSecure's hybrid infrastructure and geographically distributed workforce, the following vulnerabilities increase the attack surface:

Table 2: Identity Audit — Active Directory Account Analysis. It presents the identity audit findings from Active Directory, highlighting account categories, their current authentication state, and associated risk levels.

#	Account Category	Count	Auth Method	Stale (90+ days inactive)	Shared Credentials	MFA Enabled	Risk Level
1	Standard user accounts	370	Password only	~45 estimated	No	No	Medium
2	IT admin accounts	8	Password only	0	Yes (some)	No	Critical
3	Service accounts	12	Password only	Unknown	Yes	No	High
4	Remote access users	80	Password only	~10 estimated	No	No	High
5	Finance team accounts	40	Password only	~5 estimated	No	No	High
6	HR team accounts	25	Password only	~3 estimated	No	No	Medium
7	Contractor accounts	15	Password only	~8 estimated	No	No	High
8	Orphaned accounts	~20 estimated	Password only	Yes (all)	N/A	No	Critical

Key findings from this audit:

Orphaned accounts — accounts belonging to former employees that were never deactivated — represent an immediate critical risk. An attacker with access to leaked credentials from a former employee could log in without any detection. Shared credentials on IT admin accounts mean there is no individual audit trail — if a breach occurs through an admin account, it cannot be attributed to a specific person. Service accounts are particularly dangerous because they are often excluded from password rotation policies and run with elevated privileges.

1.3.1. Weak Authentication Mechanism

- Reliance on passwords makes systems vulnerable to:
 - Phishing attacks
 - Credential stuffing
 - Brute-force attacks
-

1.3.2. Unsecured Remote Access

- VPN access does not enforce MFA
 - Remote users across Pune and Bengaluru increase attack surface
-

1.3.3. Lack of Protection for Privileged Accounts

- Admin and IT accounts are high-value targets
 - No additional authentication layers for critical access
-

1.3.4. Legacy & Internal Systems Without MFA

- Internal applications (HR, loan processing) lack MFA support
 - Potential entry points for lateral movement
-

1.3.5. Over-Reliance on Weak OTP Methods (if used)

- SMS/email-based OTPs are susceptible to interception and SIM swapping
-

1.3.6. Absence of Centralized Authentication Policy

- No unified MFA enforcement across systems
 - Inconsistent security posture
-

1.4 Risk Prioritization

The identified risks are categorized based on impact and likelihood:

Risk Area	Risk Level	Impact	Likelihood	Justification
Admin Accounts	Critical	High	High	Full system compromise
VPN Access	Critical	High	High	External Exposure
Client Portal	High	High	High	Exposure to internet
Microsoft 365 Accounts	High	High	High	Email compromise risk
Internal Applications	Medium	High	High	Limited external exposure
General User Accounts	Medium	High	High	Entry point for lateral movement

1.5 Stakeholder Requirements

The following requirements were identified from key stakeholders:

1.5.1 IT Team (8 Members)

- Easy integration with existing AD and Microsoft 365
 - Minimal operational overhead
 - Centralized management
-

1.5.2 Management

- Improved security posture
- Regulatory compliance (financial data protection)
- Cost-effective solution

1.5.3 Employees

- Simple and fast login experience
- Minimal disruption to workflow
- Multiple authentication options

1.5.4 Security Perspective (Implied Need)

- Protection against phishing and credential attacks
 - Strong authentication for sensitive systems
-

1.6 Recommendations

Based on the assessment, the following recommendations are proposed:

1.6.1. Implement Multi-Factor Authentication (MFA)

- Enforce MFA across:
 - VPN access
 - Microsoft 365 accounts
 - Admin and privileged accounts
-

1.6.2. Adopt Strong Authentication Methods

- Use:
 - Authenticator apps (primary)
 - Hardware tokens (for critical users)
 - Biometrics (where applicable)
 - Avoid SMS as primary authentication method
-

1.6.3. Centralize Authentication Management

- Integrate MFA with:
 - Active Directory
 - SSO systems
 - Cloud identity providers
-

1.6.4. Secure Remote Access

- Enforce MFA on all VPN connections
 - Monitor remote login activity
-

1.6.5. Implement Risk-Based Authentication

- Trigger MFA based on:
 - New device
 - Unusual location
 - High-risk activity
-

1.6.6. Prepare for Compliance

- Align authentication practices with:
 - NIST guidelines
 - Financial data protection standards
-

1.6.7. Conduct User Awareness Training

- Educate users on:
 - Phishing risks
 - Safe authentication practices
 - MFA usage

These recommendations form the foundation for designing a scalable and secure MFA framework, detailed in subsequent sections of this project.